共识护航 AI Banking Agent 安全自评报告

> 项目：共识护航（银行 AI 智能体） | 日期：2026-10-20 | 环境：参赛模拟环境

一、自评范围与结论

本报告对系统的权限分级、认证、数据隔离、注入防护、一致性、恢复与审计进行自评。**结论：在模拟资金环境与模拟认证前提下，核心安全机制已实现并通过自动化测试；但正式强验证与模拟接口认可仍需主办方确认，不宣称“完全达标”。**

二、逐项自评

编号	安全项	实现	测试证据	状态
S-01	权限分级（绿/黄/红）由确定性引擎判定	`app/security/policy.py`	test_permissions	✅ 已实现
S-02	日累计≤1000 元黄色、>1000 元红色	原子校验 + 占用	test_daily_limit_upgrade_800_then_300	✅ 已实现
S-03	强验证（挑战、过期、一次性、防重放、限次）	`app/auth/challenge.py`	test_auth_challenge	✅ 已实现（模拟）
S-04	身份来自服务端会话	`current_user` 依赖	test_identity_from_session_not_body	✅ 已实现
S-05	对象级权限/数据隔离	服务层按身份过滤	test_isolation	✅ 已实现
S-06	防提示注入/恶意备注	备注作为不可信数据	test_security	✅ 已实现
S-07	防编造账户/交易结果	回执仅来自工具回读	test_transfer_timeout_then_recover	✅ 已实现
S-08	幂等（防重复扣款）	幂等键 + 原子 UPDATE	test_concurrent_same_idempotency_key	✅ 已实现
S-09	金额守恒（整数分）	原子扣款/入账	test_largest_remainder_conserves_*	✅ 已实现

编号	安全项	实现	测试证据	状态
S-10	规则版本与授权失效	旧授权 revoked	test_modify_node_invalidates_auth	✅ 已实现
S-11	故障恢复/超时回读	银行侧回读	test_transfer_timeout_then_recover	✅ 已实现
S-12	熔断/安全锁定	阈值团队配置	test_* (熔断逻辑)	✅ 已实现
S-13	完整审计（不含密钥/验证码）	`app/services/audit.py`	test_secret_not_in_audit	✅ 已实现
S-14	受限运行环境（禁用任意代码执行）	默认禁用	—	✅ 已实现
S-15	无万能管理员	接管者受角色约束	—	✅ 已实现

三、未完成 / 待确认

项	说明
正式强验证	当前为模拟 OTP，未接入人脸/短信/U 盾，需主办方确认是否接受
模拟接口验收口径	银行适配层为模拟实现，需主办方确认
越权测试覆盖率	已测跨人余额/代付/证据卡/卡片越权，未测的向量检索/实时消息通道本项目未使用（已标注）

四、已知风险

- 模拟认证不等价正式强验证（已在界面与文档醒目标记）。
- 零失误仅代表当前 128 条测试集，不代表绝对安全。
- SQLite 用于演示，生产需替换为更高并发数据库并复用同一套服务层契约。